

Industrial Security (Master)

Exercise Sheet – Section 03 Advanced Industrial Protocols

Exercise 3.1 – S7commPlus Handshake

Set up a Siemens TIA Portal connection to an S7-1200 / 1500 (simulator is fine). Capture the handshake:

1. Identify the version (S7commPlus v1, v2, v3).
2. Locate the client and server challenges in the first frames.
3. Read a public reverse-engineering paper (Gordeychik 2017, Lei 2020) and reproduce the key derivation in Python for the captured session.
4. Decrypt one read-request and verify against the variable you actually requested.

Exercise 3.2 – GOOSE Spoof in the Lab

On an authorised IEC 61850 lab (open-source: `libiec61850`):

1. Capture a normal GOOSE multicast stream.
2. Use `libiec61850` or Scapy to craft a frame with `stNum` one higher than the latest seen.
3. Inject onto the lab L2; observe the subscriber's reaction.
4. Document the only effective mitigation that worked.

Exercise 3.3 – Scapy Dissector

Pick a niche protocol of your choice (HART-IP, OPC DA over DCOM, ADS Twincat, IEC 60870-5-104).

1. Build a minimal Scapy layer (header + length + 2-3 fields).
2. Replay a captured exchange against a test client; verify it accepts the spoof.
3. Submit the Scapy module + 5 lines on its limits.

Exercise 3.4 – Fuzz Harness

Wire up `boofuzz` against a soft-PLC or sandboxed device:

1. Define one Modbus PDU with mutators on length and function code.
2. Run 5 minutes; document any crash, hang, or bus reset.
3. Map the crash to a CWE class.

Caution

Bench-isolated PLC only. Real plants *will* trip on malformed input.